

Laboratório — Sessão 5

Análise de Vulnerabilidades em Linux e Ferramentas de Auditoria

Execução de um exame de auditoria técnica automatizada para identificar desvios de conformidade em relação aos standards de segurança recomendados (CIS Benchmarks).

Serultado do comando : *root@ubuntu:\$ sudo lynis audit system*

[Lynis 3.0.9]

[+] Initializing program

```
- Detecting OS...           [ DONE ]
- Checking profiles...      [ DONE ]
```

```
Program version:          3.0.9
Operating system:         Linux
Operating system name:    Ubuntu
Operating system version: 24.04
Kernel version:           6.8.0
Hardware platform:        x86_64
Hostname:                  ubuntu
```

```
Profiles:                 /etc/lynis/default.prf
Log file:                  /var/log/lynis.log
Report file:               /var/log/lynis-report.dat
Report version:            1.0
Plugin directory:          /etc/lynis/plugins
```

```
Auditor:                  [Not Specified]
Language:                  en
Test category:             all
Test group:                all
```

- Program update status...

[NO UPDATE]

[+] System tools

- Scanning available tools...

- Checking system binaries...

[+] Plugins (phase 1)

Note: plugins have more extensive tests and may take several minutes to complete

- Plugin: debian

[

[+] Debian Tests

- Checking for system binaries that are required by Debian Tests...

- Checking /bin... [FOUND]

- Checking /sbin... [FOUND]

- Checking /usr/bin... [FOUND]

- Checking /usr/sbin... [FOUND]

- Checking /usr/local/bin... [FOUND]

- Checking /usr/local/sbin... [FOUND]

- Authentication:

- PAM (Pluggable Authentication Modules):

- libpam-tmpdir [Not Installed]

- File System Checks:

- DM-Crypt, Cryptsetup & Cryptmount:

- Checking / on /dev/vda1 [NOT ENCRYPTED]

- Checking /boot on /dev/vda16 [NOT ENCRYPTED]

- Checking /boot/efi on /dev/vda15 [NOT ENCRYPTED]

- Software:

- apt-listbugs	[Not Installed]
- apt-listchanges	[Not Installed]
- needrestart	[Installed]
- fail2ban	[Not Installed]

]

[+] Boot and services

- Service Manager	[systemd]
- Checking UEFI boot	[DISABLED]
- Checking presence GRUB2	[FOUND]
- Checking for password protection	[NONE]
- Check running services (systemctl)	[DONE]

Result: found 21 running services

- Check enabled services at boot (systemctl)	[DONE]
--	----------

Result: found 45 enabled services

- Check startup files (permissions)	[OK]
-------------------------------------	--------

- Running 'systemd-analyze security'	
- ModemManager.service:	[MEDIUM]
- containerd.service:	[UNSAFE]
- cron.service:	[UNSAFE]
- dbus.service:	[UNSAFE]
- dm-event.service:	[UNSAFE]
- dmesg.service:	[UNSAFE]
- docker.service:	[UNSAFE]
- emergency.service:	[UNSAFE]
- fwupd.service:	[PROTECTED]
- getty@tty1.service:	[UNSAFE]
- iscsid.service:	[UNSAFE]
- lvm2-lvmpolld.service:	[UNSAFE]
- lynis.service:	[UNSAFE]
- multipathd.service:	[UNSAFE]
- networkd-dispatcher.service:	[UNSAFE]
- open-vm-tools.service:	[UNSAFE]
- packagekit.service:	[UNSAFE]
- plymouth-start.service:	[UNSAFE]

- podman.service:	[UNSAFE]
- polkit.service:	[PROTECTED]
- rc-local.service:	[UNSAFE]
- rescue.service:	[UNSAFE]
- rsyslog.service:	[MEDIUM]
- serial-getty@ttyS0.service:	[UNSAFE]
- ssh.service:	[UNSAFE]
- systemd-ask-password-console.service:	[UNSAFE]
- systemd-ask-password-plymouth.service:	[UNSAFE]
- systemd-ask-password-wall.service:	[UNSAFE]
- systemd-bsod.service:	[UNSAFE]
- systemd-fsckd.service:	[UNSAFE]
- systemd-initctl.service:	[UNSAFE]
- systemd-journald.service:	[PROTECTED]
- systemd-logind.service:	[PROTECTED]
- systemd-networkd.service:	[PROTECTED]
- systemd-resolved.service:	[PROTECTED]
- systemd-rfkill.service:	[UNSAFE]
- systemd-timesyncd.service:	[PROTECTED]
- systemd-udev.service:	[MEDIUM]
- tpm-udev.service:	[UNSAFE]
- ubuntu-advantage.service:	[UNSAFE]
- udisks2.service:	[UNSAFE]
- unattended-upgrades.service:	[UNSAFE]
- uuidd.service:	[MEDIUM]
- vgauth.service:	[UNSAFE]

[+] Kernel

- Checking default run level	[RUNLEVEL 5]
- Checking CPU support (NX/PAE)	
CPU support: PAE and/or NoeXecute supported	[FOUND]
- Checking kernel version and release	[DONE]
- Checking kernel type	[DONE]
- Checking loaded kernel modules	[DONE]
Found 67 active modules	
- Checking Linux kernel configuration file	[FOUND]
- Checking default I/O kernel scheduler	[NOT FOUND]

- Checking for available kernel update [OK]
- Checking core dumps configuration
 - configuration in systemd conf files [DEFAULT]
 - configuration in /etc/profile [DEFAULT]
 - 'hard' configuration in /etc/security/limits.conf [DEFAULT]
 - 'soft' configuration in /etc/security/limits.conf [DEFAULT]
- Checking setuid core dumps configuration [PROTECTED]
- Check if reboot is needed [NO]

[+] Memory and Processes

- Checking /proc/meminfo [FOUND]
- Searching for dead/zombie processes [NOT FOUND]
- Searching for IO waiting processes [NOT FOUND]
- Search prelink tooling [NOT FOUND]

[+] Users, Groups and Authentication

- Administrator accounts [OK]
- Unique UIDs [OK]
- Consistency of group files (grpck) [OK]
- Unique group IDs [OK]
- Unique group names [OK]
- Password file consistency [OK]
- Password hashing methods [OK]
- Checking password hashing rounds [DISABLED]
- Query system users (non daemons) [DONE]
- NIS+ authentication support [NOT ENABLED]
- NIS authentication support [NOT ENABLED]
- Sudoers file(s) [FOUND]
 - Permissions for directory: /etc/sudoers.d [OK]
 - Permissions for: /etc/sudoers [OK]
 - Permissions for: /etc/sudoers.d/90-cloud-init-users [OK]
 - Permissions for: /etc/sudoers.d/README [OK]
- PAM password strength tools [SUGGESTION]
- PAM configuration files (pam.conf) [FOUND]
- PAM configuration files (pam.d) [FOUND]
- PAM modules [FOUND]
- LDAP module in PAM [NOT FOUND]

- Accounts without expire date [SUGGESTION]
- Accounts without password [OK]
- Locked accounts [OK]
- Checking user password aging (minimum) [DISABLED]
- User password aging (maximum) [DISABLED]
- Checking expired passwords [OK]
- Checking Linux single user mode authentication [OK]
- Determining default umask
 - umask (/etc/profile) [NOT FOUND]
 - umask (/etc/login.defs) [SUGGESTION]
- LDAP authentication support [NOT ENABLED]
- Logging failed login attempts [ENABLED]

[+] Shells

- Checking shells from /etc/shells
Result: found 9 shells (valid shells: 9).
- Session timeout settings/tools [NONE]
- Checking default umask values
 - Checking default umask in /etc/bash.bashrc [NONE]
 - Checking default umask in /etc/profile [NONE]

[+] File systems

- Checking mount points
 - Checking /home mount point [SUGGESTION]
 - Checking /tmp mount point [SUGGESTION]
 - Checking /var mount point [SUGGESTION]
- Query swap partitions (fstab) [NONE]
- Testing swap partitions [OK]
- Testing /proc mount (hidepid) [SUGGESTION]
- Checking for old files in /tmp [OK]
- Checking /tmp sticky bit [OK]
- Checking /var/tmp sticky bit [OK]
- ACL support root file system [ENABLED]
- Mount options of / [NON DEFAULT]

- Mount options of /boot [DEFAULT]
- Mount options of /dev [PARTIALLY HARDENED]
- Mount options of /dev/shm [PARTIALLY HARDENED]
- Mount options of /run [HARDENED]
- Total without nodev:6 noexec:7 nosuid:4 ro or noexec (W^X): 7 of total 22
- Disable kernel support of some filesystems

[+] USB Devices

- Checking usb-storage driver (modprobe config) [NOT DISABLED]
- Checking USB devices authorization [DISABLED]
- Checking USBGuard [NOT FOUND]

[+] Storage

- Checking firewire ohci driver (modprobe config) [DISABLED]

[+] NFS

- Check running NFS daemon [NOT FOUND]

[+] Name services

- Checking search domains [FOUND]
- Searching DNS domain name [UNKNOWN]
- Checking /etc/hosts
 - Duplicate entries in hosts file [NONE]
 - Presence of configured hostname in /etc/hosts [FOUND]
 - Hostname mapped to localhost [NOT FOUND]
 - Localhost mapping to IP address [OK]

[+] Ports and packages

- Searching package managers
 - Searching dpkg package manager [FOUND]
 - Querying package manager

- Query unpurged packages [FOUND]
- Checking security repository in sources.list.d directory [OK]
- Checking APT package database [OK]
- Checking vulnerable packages [WARNING]
- Checking upgradeable packages [SKIPPED]
- Checking package audit tool [INSTALLED]
- Found: apt-get
- Toolkit for automatic upgrades (unattended-upgrade) [FOUND]

[+] Networking

- Checking IPv6 configuration [ENABLED]
 - Configuration method [AUTO]
 - IPv6 only [NO]
- Checking configured nameservers
 - Testing nameservers
 - Nameserver: 8.8.8.8 [OK]
 - Nameserver: 1.1.1.1 [OK]
 - Minimal of 2 responsive nameservers [OK]
 - DNSSEC supported (systemd-resolved) [UNKNOWN]
 - Checking default gateway [DONE]
 - Getting listening ports (TCP/UDP) [DONE]
 - Checking promiscuous interfaces [OK]

- Checking waiting connections [OK]
- Checking status DHCP client [RUNNING]
- Checking for ARP monitoring software [NOT FOUND]
- Uncommon network protocols [0]

[+] Printers and Spools

- Checking cups daemon [NOT FOUND]
- Checking lp daemon [NOT RUNNING]

[+] Software: e-mail and messaging

[+] Software: firewalls

- Checking iptables kernel module [FOUND]
- Checking iptables policies of chains [FOUND]
- Checking for empty ruleset [OK]
- Checking for unused rules [FOUND]
- Checking host based firewall [ACTIVE]

[+] Software: webserver

- Checking Apache [NOT FOUND]
- Checking nginx [NOT FOUND]

[+] SSH Support

- Checking running SSH daemon [FOUND]
- Searching SSH configuration [FOUND]
- OpenSSH option: AllowTcpForwarding [SUGGESTION]
- OpenSSH option: ClientAliveCountMax [SUGGESTION]
- OpenSSH option: ClientAliveInterval [OK]

- OpenSSH option: FingerprintHash [OK]
- OpenSSH option: GatewayPorts [OK]
- OpenSSH option: IgnoreRhosts [OK]
- OpenSSH option: LoginGraceTime [OK]
- OpenSSH option: LogLevel [SUGGESTION]
- OpenSSH option: MaxAuthTries [SUGGESTION]
- OpenSSH option: MaxSessions [SUGGESTION]
- OpenSSH option: PermitRootLogin [SUGGESTION]
- OpenSSH option: PermitUserEnvironment [OK]
- OpenSSH option: PermitTunnel [OK]
- OpenSSH option: Port [SUGGESTION]
- OpenSSH option: PrintLastLog [OK]
- OpenSSH option: StrictModes [OK]
- OpenSSH option: TCPKeepAlive [SUGGESTION]
- OpenSSH option: UseDNS [OK]
- OpenSSH option: X11Forwarding [OK]
- OpenSSH option: AllowAgentForwarding [SUGGESTION]
- OpenSSH option: AllowUsers [NOT FOUND]
- OpenSSH option: AllowGroups [NOT FOUND]

[+] SNMP Support

- Checking running SNMP daemon [NOT FOUND]

[+] Databases

No database engines found

[+] LDAP Services

- Checking OpenLDAP instance [NOT FOUND]

[+] PHP

- Checking PHP [NOT FOUND]

[+] Squid Support

- Checking running Squid daemon [NOT FOUND]

[+] Logging and files

- | | |
|--|-----------------|
| - Checking for a running log daemon | [OK] |
| - Checking Syslog-NG status | [NOT FOUND] |
| - Checking systemd journal status | [FOUND] |
| - Checking Metalog status | [NOT FOUND] |
| - Checking RSyslog status | [FOUND] |
| - Checking RFC 3195 daemon status | [NOT FOUND] |
| - Checking minilogd instances | [NOT FOUND] |
| - Checking logrotate presence | [OK] |
| - Checking remote logging | [NOT ENABLED] |
| - Checking log directories (static list) | [DONE] |
| - Checking open log files | [DONE] |
| - Checking deleted files in use | [DONE] |

[+] Insecure services

- | | |
|-------------------------------------|---------------|
| - Installed inetd package | [NOT FOUND] |
| - Installed xinetd package | [OK] |
| - xinetd status | |
| - Installed rsh client package | [OK] |
| - Installed rsh server package | [OK] |
| - Installed telnet client package | [OK] |
| - Installed telnet server package | [NOT FOUND] |
| - Checking NIS client installation | [OK] |
| - Checking NIS server installation | [OK] |
| - Checking TFTP client installation | [OK] |
| - Checking TFTP server installation | [OK] |

[+] Banners and identification

- | | |
|---------------------------|-----------|
| - /etc/issue | [FOUND] |
| - /etc/issue contents | [WEAK] |
| - /etc/issue.net | [FOUND] |
| - /etc/issue.net contents | [WEAK] |

[+] Scheduled tasks

- Checking crontab and cronjob files [DONE]

[+] Accounting

- Checking accounting information [NOT FOUND]
- Checking sysstat accounting data [DISABLED]
- Checking auditd [NOT FOUND]

[+] Time and Synchronization

- NTP daemon found: systemd (timesyncd) [FOUND]
- Checking for a running NTP daemon or client [OK]
- Last time synchronization [1558s]

[+] Cryptography

- Checking for expired SSL certificates [0/127] [NONE]

[WARNING]: Test CRYPT-7902 had a long execution: 11.866375 seconds

- Found 0 encrypted and 1 unencrypted swap devices in use. [OK]
- Kernel entropy is sufficient [YES]
- HW RNG & rngd [NO]
- SW prng [NO]
- MOR variable not found [WEAK]

[+] Virtualization

[+] Containers

- Docker
- Docker daemon [RUNNING]
- Docker info output (warnings) [NONE]
- Containers
- Total containers [0]
- File permissions [OK]

[+] Security frameworks

- Checking presence AppArmor [FOUND]
- Checking AppArmor status [ENABLED]
 - Found 44 unconfined processes
- Checking presence SELinux [NOT FOUND]
- Checking presence TOMOYO Linux [NOT FOUND]
- Checking presence grsecurity [NOT FOUND]
- Checking for implemented MAC framework [OK]

[+] Software: file integrity

- Checking file integrity tools
- dm-integrity (status) [DISABLED]
- dm-verity (status) [DISABLED]
- Checking presence integrity tool [NOT FOUND]

[+] Software: System tooling

- Checking automation tooling
- Automation tooling [NOT FOUND]
- Checking for IDS/IPS tooling [NONE]

[+] Software: Malware

pgrep: pattern that searches for process name longer than 15 characters will result in zero matches

Try `pgrep -f` option to match against the complete command line.

- Malware software components [NOT FOUND]

[+] File Permissions

- Starting file permissions check

File: /boot/grub/grub.cfg	[OK]
File: /etc/crontab	[SUGGESTION]
File: /etc/group	[OK]
File: /etc/group-	[OK]
File: /etc/hosts.allow	[OK]
File: /etc/hosts.deny	[OK]
File: /etc/issue	[OK]
File: /etc/issue.net	[OK]
File: /etc/passwd	[OK]
File: /etc/passwd-	[OK]
File: /etc/ssh/sshd_config	[SUGGESTION]
Directory: /root/.ssh	[OK]
Directory: /etc/cron.d	[SUGGESTION]
Directory: /etc/cron.daily	[SUGGESTION]
Directory: /etc/cron.hourly	[SUGGESTION]
Directory: /etc/cron.weekly	[SUGGESTION]
Directory: /etc/cron.monthly	[SUGGESTION]

[+] Home directories

- Permissions of home directories	[OK]
- Ownership of home directories	[OK]
- Checking shell history files	[OK]

[+] Kernel Hardening

- Comparing sysctl key pairs with scan profile
 - dev.tty.ldisc_autoload (exp: 0) [DIFFERENT]
 - fs.protected_fifos (exp: 2) [DIFFERENT]
 - fs.protected_hardlinks (exp: 1) [OK]
 - fs.protected_regular (exp: 2) [OK]
 - fs.protected_symlinks (exp: 1) [OK]
 - fs.suid_dumpable (exp: 0) [DIFFERENT]
 - kernel.core_uses_pid (exp: 1) [DIFFERENT]
 - kernel.ctrl-alt-del (exp: 0) [OK]
 - kernel.dmesg_restrict (exp: 1) [OK]
 - kernel.kptr_restrict (exp: 2) [DIFFERENT]
 - kernel.modules_disabled (exp: 1) [DIFFERENT]
 - kernel.perf_event_paranoid (exp: 3) [DIFFERENT]
 - kernel.randomize_va_space (exp: 2) [OK]
 - kernel.sysrq (exp: 0) [DIFFERENT]
 - kernel.unprivileged_bpf_disabled (exp: 1) [DIFFERENT]
 - kernel.yama.ptrace_scope (exp: 1 2 3) [OK]
 - net.core.bpf_jit_harden (exp: 2) [DIFFERENT]
 - net.ipv4.conf.all.accept_redirects (exp: 0) [OK]
 - net.ipv4.conf.all.accept_source_route (exp: 0) [OK]
 - net.ipv4.conf.all.bootp_relay (exp: 0) [OK]
 - net.ipv4.conf.all.forwarding (exp: 0) [DIFFERENT]
 - net.ipv4.conf.all.log_martians (exp: 1) [DIFFERENT]
 - net.ipv4.conf.all.mc_forwarding (exp: 0) [OK]
 - net.ipv4.conf.all.proxy_arp (exp: 0) [OK]
 - net.ipv4.conf.all.rp_filter (exp: 1) [DIFFERENT]
 - net.ipv4.conf.all.send_redirects (exp: 0) [DIFFERENT]
 - net.ipv4.conf.default.accept_redirects (exp: 0) [DIFFERENT]
 - net.ipv4.conf.default.accept_source_route (exp: 0) [DIFFERENT]
 - net.ipv4.conf.default.log_martians (exp: 1) [DIFFERENT]
 - net.ipv4.icmp_echo_ignore_broadcasts (exp: 1) [OK]
 - net.ipv4.icmp_ignore_bogus_error_responses (exp: 1) [OK]
 - net.ipv4.tcp_syncookies (exp: 1) [OK]
 - net.ipv4.tcp_timestamps (exp: 0 1) [OK]
 - net.ipv6.conf.all.accept_redirects (exp: 0) [DIFFERENT]

- net.ipv6.conf.all.accept_source_route (exp: 0) [OK]
- net.ipv6.conf.default.accept_redirects (exp: 0) [DIFFERENT]
- net.ipv6.conf.default.accept_source_route (exp: 0) [OK]

[+] Hardening

- Installed compiler(s) [FOUND]
- Installed malware scanner [NOT FOUND]
- Non-native binary formats [FOUND]

[+] Custom tests

- Running custom tests... [NONE]

[+] Plugins (phase 2)

-[Lynis 3.0.9 Results]-

Warnings (1):

! Found one or more vulnerable packages. [PKGS-7392]
<https://cisofy.com/lynis/controls/PKGS-7392/>

Suggestions (50):

* This release is more than 4 months old. Check the website or GitHub to see if there is an update available. [LYNIS]

<https://cisofy.com/lynis/controls/LYNIS/>

* Install libpam-tmpdir to set \$TMP and \$TMPDIR for PAM sessions [DEB-0280]
<https://cisofy.com/lynis/controls/DEB-0280/>

* Install apt-listbugs to display a list of critical bugs prior to each APT installation. [DEB-0810]

<https://cisofy.com/lynis/controls/DEB-0810/>

* Install apt-listchanges to display any significant changes prior to any upgrade via APT. [DEB-0811]

<https://cisofy.com/lynis/controls/DEB-0811/>

- * Install fail2ban to automatically ban hosts that commit multiple authentication errors. [DEB-0880]

<https://cisofy.com/lynis/controls/DEB-0880/>

- * Set a password on GRUB boot loader to prevent altering boot configuration (e.g. boot in single user mode without password) [BOOT-5122]

<https://cisofy.com/lynis/controls/BOOT-5122/>

- * Consider hardening system services [BOOT-5264]

- Details : Run '/usr/bin/systemd-analyze security SERVICE' for each service

<https://cisofy.com/lynis/controls/BOOT-5264/>

- * If not required, consider explicit disabling of core dump in /etc/security/limits.conf file [KRNL-5820]

<https://cisofy.com/lynis/controls/KRNL-5820/>

- * Configure password hashing rounds in /etc/login.defs [AUTH-9230]

<https://cisofy.com/lynis/controls/AUTH-9230/>

- * Install a PAM module for password strength testing like pam_cracklib or pam_passwdqc [AUTH-9262]

<https://cisofy.com/lynis/controls/AUTH-9262/>

- * When possible set expire dates for all password protected accounts [AUTH-9282]

<https://cisofy.com/lynis/controls/AUTH-9282/>

- * Configure minimum password age in /etc/login.defs [AUTH-9286]

<https://cisofy.com/lynis/controls/AUTH-9286/>

- * Configure maximum password age in /etc/login.defs [AUTH-9286]

<https://cisofy.com/lynis/controls/AUTH-9286/>

- * Default umask in /etc/login.defs could be more strict like 027 [AUTH-9328]

<https://cisofy.com/lynis/controls/AUTH-9328/>

- * To decrease the impact of a full /home file system, place /home on a separate partition [FILE-6310]

<https://cisofy.com/lynis/controls/FILE-6310/>

* To decrease the impact of a full /tmp file system, place /tmp on a separate partition [FILE-6310]

<https://cisofy.com/lynis/controls/FILE-6310/>

* To decrease the impact of a full /var file system, place /var on a separate partition [FILE-6310]

<https://cisofy.com/lynis/controls/FILE-6310/>

* vm.swappiness set to: 0. Consider setting value to minimum of 1 for minimizing swappiness, but not quite disabling it. Will prevent OOM killer from killing processes when running out of physical memory. [FILE-6394]

<https://cisofy.com/lynis/controls/FILE-6394/>

* Disable drivers like USB storage when not used, to prevent unauthorized storage or data theft [USB-1000]

<https://cisofy.com/lynis/controls/USB-1000/>

* Check DNS configuration for the dns domain name [NAME-4028]

<https://cisofy.com/lynis/controls/NAME-4028/>

* Purge old/removed packages (1 found) with aptitude purge or dpkg --purge command. This will cleanup old configuration files, cron jobs and startup scripts. [PKGS-7346]

<https://cisofy.com/lynis/controls/PKGS-7346/>

* Install debsums utility for the verification of packages with known good database. [PKGS-7370]

<https://cisofy.com/lynis/controls/PKGS-7370/>

* Update your system with apt-get update, apt-get upgrade, apt-get dist-upgrade and/or unattended-upgrades [PKGS-7392]

<https://cisofy.com/lynis/controls/PKGS-7392/>

* Install package apt-show-versions for patch management purposes [PKGS-7394]

<https://cisofy.com/lynis/controls/PKGS-7394/>

* Determine if protocol 'dcp' is really needed on this system [NETW-3200]

<https://cisofy.com/lynis/controls/NETW-3200/>

- * Determine if protocol 'sctp' is really needed on this system [NETW-3200]

<https://cisofy.com/lynis/controls/NETW-3200/>

- * Determine if protocol 'rds' is really needed on this system [NETW-3200]

<https://cisofy.com/lynis/controls/NETW-3200/>

- * Determine if protocol 'tipc' is really needed on this system [NETW-3200]

<https://cisofy.com/lynis/controls/NETW-3200/>

- * Check iptables rules to see which rules are currently not used [FIRE-4513]

<https://cisofy.com/lynis/controls/FIRE-4513/>

- * Consider hardening SSH configuration [SSH-7408]

- Details : AllowTcpForwarding (set YES to NO)

<https://cisofy.com/lynis/controls/SSH-7408/>

- * Consider hardening SSH configuration [SSH-7408]

- Details : ClientAliveCountMax (set 3 to 2)

<https://cisofy.com/lynis/controls/SSH-7408/>

- * Consider hardening SSH configuration [SSH-7408]

- Details : LogLevel (set INFO to VERBOSE)

<https://cisofy.com/lynis/controls/SSH-7408/>

- * Consider hardening SSH configuration [SSH-7408]

- Details : MaxAuthTries (set 6 to 3)

<https://cisofy.com/lynis/controls/SSH-7408/>

- * Consider hardening SSH configuration [SSH-7408]

- Details : MaxSessions (set 10 to 2)

<https://cisofy.com/lynis/controls/SSH-7408/>

- * Consider hardening SSH configuration [SSH-7408]

- Details : PermitRootLogin (set YES to (FORCED-COMMANDS-ONLY|NO|PROHIBIT-PASSWORD|WITHOUT-PASSWORD))

<https://cisofy.com/lynis/controls/SSH-7408/>

- * Consider hardening SSH configuration [SSH-7408]
 - Details : Port (set 22 to)
<https://cisofy.com/lynis/controls/SSH-7408/>
- * Consider hardening SSH configuration [SSH-7408]
 - Details : TCPKeepAlive (set YES to NO)
<https://cisofy.com/lynis/controls/SSH-7408/>
- * Consider hardening SSH configuration [SSH-7408]
 - Details : AllowAgentForwarding (set YES to NO)
<https://cisofy.com/lynis/controls/SSH-7408/>
- * Enable logging to an external logging host for archiving purposes and additional protection [LOGG-2154]
<https://cisofy.com/lynis/controls/LOGG-2154/>
- * Add a legal banner to /etc/issue, to warn unauthorized users [BANN-7126]
<https://cisofy.com/lynis/controls/BANN-7126/>
- * Add legal banner to /etc/issue.net, to warn unauthorized users [BANN-7130]
<https://cisofy.com/lynis/controls/BANN-7130/>
- * Enable process accounting [ACCT-9622]
<https://cisofy.com/lynis/controls/ACCT-9622/>
- * Enable sysstat to collect accounting (disabled) [ACCT-9626]
<https://cisofy.com/lynis/controls/ACCT-9626/>
- * Enable auditd to collect audit information [ACCT-9628]
<https://cisofy.com/lynis/controls/ACCT-9628/>
- * Install a file integrity tool to monitor changes to critical and sensitive files [FINT-4350]
<https://cisofy.com/lynis/controls/FINT-4350/>
- * Determine if automation tools are present for system management [TOOL-5002]
<https://cisofy.com/lynis/controls/TOOL-5002/>
- * Consider restricting file permissions [FILE-7524]

- Details : See screen output or log file
- Solution : Use chmod to change file permissions
<https://cisofy.com/lynis/controls/FILE-7524/>

* One or more sysctl values differ from the scan profile and could be tweaked [KRNL-6000]

- Solution : Change sysctl value or disable test (skip-test=KRNL-6000:<sysctl-key>)

<https://cisofy.com/lynis/controls/KRNL-6000/>

* Harden compilers like restricting access to root user only [HRDN-7222]

<https://cisofy.com/lynis/controls/HRDN-7222/>

* Harden the system by installing at least one malware scanner, to perform periodic file system scans [HRDN-7230]

- Solution : Install a tool like rkhunter, chkrootkit, OSSEC

<https://cisofy.com/lynis/controls/HRDN-7230/>

Follow-up:

-
- Show details of a test (lynis show details TEST-ID)
 - Check the logfile for all details (less /var/log/lynis.log)
 - Read security controls texts (<https://cisofy.com>)
 - Use --upload to upload data to central system (Lynis Enterprise users)
-

Lynis security scan details:

Hardening index : 60 [#####]

Tests performed : 262

Plugins enabled : 1

Components:

- Firewall [V]
- Malware scanner [X]

Scan mode:

Normal [V] Forensics [] Integration [] Pentest []

Lynis modules:

- Compliance status [?]
- Security audit [V]
- Vulnerability scan [V]

Files:

- Test and debug information : /var/log/lynis.log
- Report data : /var/log/lynis-report.dat

Lynis 3.0.9

Auditing, system hardening, and compliance for UNIX-based systems
(Linux, macOS, BSD, and others)

2007-2021, CISOfy - <https://cisofy.com/lynis/>

Enterprise support available (compliance, plugins, interface and tools)

Mini-relatório técnico.

Analisando o resultado **Lynis 3.0.9** apresentado, é possível chegar a seguinte resultado.

1) Hardening Score Inicial

No entanto, pela quantidade de verificações aprovadas e pelo número de sugestões (50) e apenas **1 Warning**, estima-se que o sistema tenha um **Hardening Score inicial entre 60 e 70 pontos**.

Analisando pelo comando também apresentou o resultado dentro do intervalo.

```
root@ubuntu:~$ grep "hardening_index" /var/log/lynis-report.dat
hardening_index=60
```

Essa estimativa baseia-se em:

- a) Apenas **1 Warning crítico**;
- b) Diversas recomendações de melhoria;
- c) Muitos parâmetros do kernel ainda com valores diferentes dos recomendados;
- d) Firewall ativo;
- e) AppArmor ativo;
- f) SSH configurado, mas ainda com opções de endurecimento pendentes.

2) Os avisos encontrados (Warnings/Suggestions relevantes)

O relatório apresenta apenas **1 Warning**:

Warning	Impacto	Prioridade
Found one or more vulnerable packages (PKGS-7392)	Existem pacotes instalados com vulnerabilidades conhecidas.	Alta

Este é o aviso mais importante do relatório, pois pode permitir exploração por atacantes caso os pacotes não sejam atualizados.

Principais fragilidades

Boot

- 1) GRUB sem senha
- 2) UEFI desativado
- 3) Muitos serviços classificados como **UNSAFE** pelo systemd-analyze security

Autenticação

- ✓ Não existe política de complexidade de senha
- ✓ Tamanho mínima da senha desativada
- ✓ Tamanho máxima da senha desativada
- ✓ Contas sem data de expiração
- ✓ Umask padrão pouco restritiva

Sistema de Arquivos

Não existem partições separadas para:

- ✓ /home
- ✓ /tmp
- ✓ /var

Além disso:

- ✓ swap não está criptografada
- ✓ disco não está criptografado

Kernel Hardening

Diversos parâmetros estão diferentes do recomendado, entre eles:

- ✓ kernel.modules_disabled
- ✓ kernel.kptr_restrict
- ✓ kernel.sysrq
- ✓ fs.suid_dumpable
- ✓ dev.tty.ldisc_autoload
- ✓ kernel.perf_event_paranoid
- ✓ net.ipv4.conf.all.forwarding
- ✓ net.ipv4.conf.all.send_redirects

- ✓ net.ipv6.conf.all.accept_redirects

Esses parâmetros representam oportunidades de melhoria do sistema.

SSH

Ainda podem ser fortalecidos:

- ✓ PermitRootLogin
- ✓ MaxAuthTries
- ✓ MaxSessions
- ✓ TCPKeepAlive
- ✓ AllowAgentForwarding
- ✓ AllowUsers
- ✓ AllowGroups
- ✓ Porta padrão (22)

Sugestões prioritárias

Recomenda-se implementar as melhorias na seguinte ordem:

Ação
Atualizar pacotes vulneráveis
Instalar Fail2Ban
Configurar senha no GRUB
Endurecer configuração do SSH
Aplicar parâmetros de hardening via sysctl
Configurar política de senhas (PAM)
Definir umask 027
Instalar auditd
Criar partições separadas para /tmp, /home e /var
Criptografar disco e swap

3) As medidas corretivas propostas para as duas vulnerabilidades selecionadas

Correção recomendada para BOOT-5122

O controlo **BOOT-5122** do Lynis indica que o **GRUB2** não está protegido por palavra-passe.

Sem essa proteção, um utilizador com acesso físico ao computador pode editar os parâmetros de arranque, iniciar o sistema em **modo de utilizador único (single-user mode)** ou alterar opções do kernel para obter privilégios elevados.

Correção recomendada

A recomendação é **configurar uma palavra-passe para o GRUB2**, impedindo alterações não autorizadas ao menu de arranque.

Correção recomendada para BOOT-5264

O Lynis detetou serviços do sistema classificados como **UNSAFE**, indicando que não utilizam todas as funcionalidades de isolamento e proteção disponibilizadas pelo systemd.

Correção recomendada:

Analisar cada serviço com `systemd-analyze security` e aplicar diretivas de hardening, como `NoNewPrivileges=yes`, `PrivateTmp=yes`, `ProtectSystem=strict`, `ProtectHome=yes` e `PrivateDevices=yes`, de acordo com a compatibilidade de cada serviço.

Excerto do relatório Lynis /var/log/lynis-report.dat

```
root@ubuntu:~$ cat /var/log/lynis-report.dat
# Lynis Report
report_version_major=1
report_version_minor=0
report_datetime_start=2026-07-27 22:29:41
auditor=[Not Specified]
lynis_version=3.0.9
os=Linux
os_name=Ubuntu
os_fullname=Ubuntu 24.04.4 LTS
os_version=24.04
linux_version=Ubuntu
os_kernel_version=6.8.0
os_kernel_version_full=6.8.0-136-generic
hostname=ubuntu
test_category=all
test_group=all
plugin_directory=/etc/lynis/plugins
lynis_update_available=0
suggestion[]=LYNIS|This release is more than 4 months old. Check the website or GitHub to see if there is an update available.|-|-|
binaries_count=1828
binaries_suid_count=/usr/bin/chfn /usr/bin/chsh /usr/bin/fusermount /usr/bin/fusermount3 /usr/bin/gpasswd /usr/bin/mount /usr/bin/newgidmap /usr/bin/newgrp /usr/bin/newuidmap /usr/bin/passwd /usr/bin/sg /usr/bin/su /usr/bin/sudo /usr/bin/sudoedit /usr/bin/umount
binaries_sgid_count=/usr/bin/chage /usr/bin/crontab /usr/bin/expiry /usr/bin/ssh-agent /usr/sbin/pam_extrausers_chkpwd /usr/sbin/unix_chkpwd
binary_paths=/usr/bin,/usr/sbin,/usr/local/bin,/usr/local/sbin
vm=1
vmtype=kvm
container=0
systemd=1
plugin_enabled_phase1[]=debian|1.0.1|
suggestion[]=DEB-0280|Install libpam-tmpdir to set $TMP and $TMPDIR for PAM sessions|-|-|
suggestion[]=DEB-0810|Install apt-listbugs to display a list of critical bugs prior to each APT installation.|-|-|
```